



ΤΜΗΜΑ ΠΛΗΡΟΦΟΡΙΚΗΣ & ΤΗΛΕΠΙΚΟΙΝΩΝΙΩΝ
ΣΧΟΛΗ ΠΛΗΡΟΦΟΡΙΚΗΣ & ΤΗΛΕΠΙΚΟΙΝΩΝΙΩΝ
ΠΑΝΕΠΙΣΤΗΜΙΟ ΙΩΑΝΝΙΝΩΝ

Βάσεις Δεδομένων

Μάθημα 8, 9 – Σχεσιακή άλγεβρα - JOINS - Πολιτικές
Ασφάλειας

Διδάσκων
Δρ Ιωάννης Στύλιος



Περιεχόμενα Μαθήματος

Τι είδαμε στο προηγούμενο μάθημα

- Υλοποίηση βάσης με SQL.
 - Εισαγωγή στην Σχεσιακή Άλγεβρα.
 - Εισαγωγή στα Ερωτήματα.
- 



Περιεχόμενα Μαθήματος

Τι θα δούμε σήμερα

- Συζήτηση τρίτης εργασίας: Υλοποίηση βάσης με SQL.
 - Σχεσιακή άλγεβρα: Καρτεσιανό γινόμενο, Φυσική σύνδεση.
 - Πολιτικές Ασφάλειας.
- 

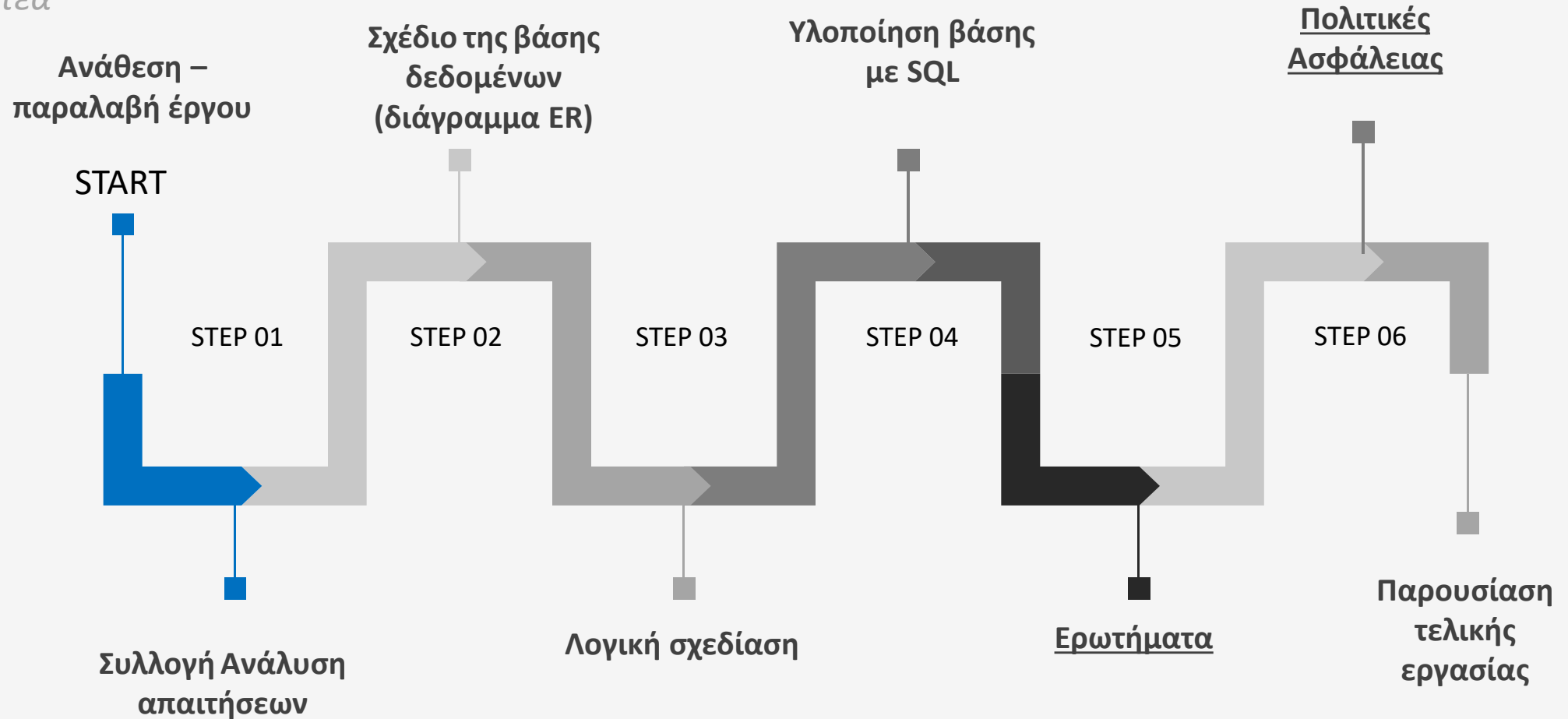
Εργασία μαθήματος (ομαδικό project)

Συζήτηση τρίτης εργασίας: Υλοποίηση βάσης με SQL.



Εργασία

Παραδοτέα



Τι είδαμε στο προηγούμενο μάθημα

Σχεσιακή Άλγεβρα



A) Επιλογή (selection)

- Επιλογή ενός **υποσυνόλου** των πλειάδων μιας σχέσης που ικανοποιεί μια **συνθήκη επιλογής**

$\sigma_{\langle \text{συνθήκη επιλογής} \rangle}$ (**<όνομα σχέσης>**)

- **Συνθήκη επιλογής:** μια ή περισσότερες **προτάσεις** που συνδέονται με λογικούς τελεστές (AND, OR, NOT)
- **Προτάσεις:** συγκρίνουν ($=, >, <, \neq, \leq, \geq$) ένα γνώρισμα με
 - ένα άλλο γνώρισμα, ή
 - μια τιμή

B) Προβολή (projection)

- Επιστροφή **συγκεκριμένων γνωρισμάτων** (στηλών)

$\pi_{\langle \text{λίστα γνωρισμάτων} \rangle} (\langle \text{όνομα σχέσης} \rangle)$

- Στις πλειάδες που επιστρέφονται **δεν εμφανίζονται διπλότυπα**
- Τα γνωρίσματα έχουν την ίδια διάταξη
- Ο τελεστής είναι μοναδιαίος
- Ο βαθμός της επιστρεφόμενης σχέσης είναι ίσος με τον αριθμό των γνωρισμάτων στη $\langle \text{λίστα γνωρισμάτων} \rangle$
- Το πλήθος πλειάδων είναι μικρότερο ή ίσο με την αρχική σχέση

Σχεσιακή Άλγεβρα

Καρτεσιανό γινόμενο



Σχήμα Τράπεζας

- Branch-scheme = (br-name, assets, br-city)
- Customer-scheme = (cust-name, street, cust-city)
- Deposit-scheme = (br-name, acc-number, cust-name, balance)
- Borrow-scheme = (br-name, loan-number, cust-name, amount)

Παράδειγμα

Deposit-scheme = (br-name, acc-number, cust-name, balance)

<i>br-name</i>	<i>loan-number</i>	<i>cust-name</i>	<i>amount</i>
Ακαδημία	11	Αλυσάφης	1100
Σόλωνος	25	Ναξάκης	1212
Λάρισα	34	Κουκλάκης	5236
Ακαδημία	45	Τόκης	2312
Αγορά	55	Κώτσας	7000
Αριστοτέλους	60	Χαρόβας	100
Σόλωνος	70	Πίσσας	3222
Ακαδημία	80	Γκαμίλης	9090
Κέντρο	80	Κουκλάκης	1560
Μητροπόλεως	90	Μαντάς	2470
Σόλωνος	98	Λάμπρου	6310

- Άλλο παράδειγμα:

Customer-scheme = (cust-name, street, cust-city)

<i>Cust-name</i>	<i>street</i>	<i>cust-city</i>
Αλυσάφης	Νικομηδείας	Αθήνα
Ναξάκης	Κορωνίδος	Αθήνα
Κουκλάκης	Βάρδα	Θεσ/νίκη
Τόκης	Καρύστου	Θεσ/νίκη
Χαρόβας	Αθηνών	Κοζάνη
Πίσσας	Τσιμισκή	Θήβα
Γκαμίλης	Περάματος	Αθήνα
Παπαδάκης	Αγνής	Αθήνα
Μαντάς	Ηρακλείου	Μεσολόγγι
Λάμπρου	Αρτας	Αγρίνιο
Κώτσας	Μάνης	Αθήνα
Μπάτης	Κούμα	Χανιά
Μαρμόρκος	Ανταίου	Φλώρινα

Περισσότεροι πίνακες

- Σπάνια χρειαζόμαστε δεδομένα από έναν μόνο πίνακα
- Τι κάνουμε τότε ?
- Παράδειγμα: Αρ. λογαριασμών που έχουν αρτινοί πελάτες
 - Χρειαζόμαστε τον πίνακα Deposit
 - Χρειαζόμαστε όμως και την πόλη του πελάτη (πίνακας Customer)
- Πώς θα τους φέρουμε σε «επαφή»?

Καρτεσιανό γινόμενο

- Συνδυασμός **όλα-με-όλα** (σύμβολο X)
 - Παράδειγμα: customer X deposit
 - Όλες οι στήλες και των δύο πινάκων.
 - Κάθε γραμμή του ενός πίνακα συνδυάζεται με όλες τις γραμμές του άλλου πίνακα
 - Σχήμα: (cust-name, street, cust-city, br-name, acc-number, cust-name, balance)
-
- Από τον πίνακα Customer
- Από τον πίνακα Deposit

Καρτεσιανό γινόμενο

- Πρόβλημα: δύο στήλες με όνομα cust-name
- Λύση: «ονοματεπώνυμο» στήλης

Customer.cust-name ---- account.cust-name

Πλήρες όνομα: bankDB.customer.cust-name

- Όλη η πληροφορία που μπορεί να χρειαζόμαστε είναι εκεί.
- Υπάρχει όμως και αρκετή περιττή πληροφορία:
- Τι νόημα έχει να συνδυαστεί ο πελάτης Παππάς με το λογαριασμό του πελάτη Πέτρου??
- Αντίστροφη ερώτηση: **ΠΟΤΕ έχει νόημα** ο συνδυασμός?

Καρτεσιανό γινόμενο

- Απάντηση: όταν οι κοινές στήλες έχουν την ίδια τιμή!

Cust-city	Address	Cust-name
Αθήνα	...	Πέτρου
Λάρισα	...	Παύλου
Λάρισα		Αθανασίου
Βόλος	...	Βλάχος

Cust-name	Acc-no	Br-name	Balance
Πέτρου	1100	Κέντρο	1100
Παύλου	756	Ομόνοια	1200
Αθανασίου	12228	Β. Πύργου	800
Βλάχος	131313	Λ. Πύργος	0

- Δεν έχει νόημα να συνδυάσουμε τον Πέτρου με το λογαριασμό 756: Συνδέω το λογαριασμό του Παύλου με τα στοιχεία του Πέτρου!
- Πως συνδέουμε κοινές στήλες έχουν την ίδια τιμή; Θα το δούμε στην συνέχεια (Φυσική σύνδεση).

Σχεσιακή Άλγεβρα

Φυσική σύνδεση



Φυσική σύνδεση

- Έχει νόημα όταν συνδέσω τον Πέτρου με τον λογαριασμό 1100.

Cust-city	Address	Cust-name	Cust-name	Acc-no	Br-name	Balance
αθήνα	...	Πέτρου	Πέτρου	1100	Κέντρο	1100
Λάρισα	...	Παύλου	Παύλου	756	Ομόνοια	1200
Λάρισα		Αθανασίου	Αθανασίου	12228	Β. Πύργου	800
Βόλος	...	Βλάχος	Βλάχος	131313	Λ.Πύργος	0

- Φέρνουμε δίπλα σε κάθε δάνειο τα στοιχεία του πελάτη που το έχει.
- Πώς?
- Από το καρτεσιανό γινόμενο («όλα-με-όλα») κρατάμε μόνο όσες γραμμές έχουν **ίδια τιμή** στο **κοινό πεδίο**.

Φυσική σύνδεση

- Όταν συνδέω δύο γραμμές με **ίδια τιμή** στο **κοινό πεδίο**, παίρνω τη

ΦΥΣΙΚΗ ΣΥΝΔΕΣΗ (NATURAL JOIN)

- Τύπος:

Deposit $\bowtie$ Customer =

$\sigma_{\text{Deposit.Cust-name} = \text{Customer.cust-name}} (\text{Deposit} \times \text{Customer})$

Φυσική Σύνδεση

συνένωση ισότητας όπου παραλείπουμε το γνώρισμα της δεύτερης σχέσης από το αποτέλεσμα

R

A	B
1	2
3	4

S

B	C	D
2	5	6
4	7	8
9	10	11

R * S

A	B	C	D
1	2	5	6
3	4	7	8

Φυσική σύνδεση

- Εφαρμόζουμε το μηχανισμό με τον οποίο γίνεται η σύνδεση.
- Πίνακες: FROM Customer, Borrow.
- Συνθήκη: WHERE Customer.Cust-name = Borrow.Cust-name
- Άρα: Αρ.δανείου, όνομα πελάτη, πόλη πελάτη.

ΦΥΣΙΚΗ
ΣΥΝΔΕΣΗ



```
SELECT loan-no, Borrow.cust-name, cust-city FROM Customer, Borrow
WHERE Customer.Cust-name = Borrow.Cust-name
```

Παραδείγματα

- Αρ. λογαριασμού σε καταστήματα της Αθήνας.

```
SELECT acc-no FROM Deposit, branch  
WHERE branch.br-name = deposit.br-name AND  
Br-city = 'Αθήνα'
```

- Αρ. δανείου και οδός πελάτη για πελάτες με δάνεια πάνω από 50000.

```
SELECT loan-no, street FROM Borrow, customer  
WHERE Borrow.cust-name = customer.cust-name AND  
Amount > 50000
```

Παραδείγματα

- Ονόματα δανειοληπτών που έχουν τα δάνεια 961 και 1003 και τα αντίστοιχα καταστήματα και πόλεις των δανείων.

```
SELECT cust-name, branch.br-name, br-city FROM Borrow, branch  
WHERE branch.br-name = borrow.br-name AND  
(loan-no = 961 OR loan-no = 1003)
```

- Αρ. λογαριασμού και όνομα πελάτη με λογαριασμό στην πόλη του.

```
SELECT acc-no, deposit.cust-name FROM Deposit, branch, customer  
WHERE branch.br-name = deposit.br-name AND customer.cust-name =  
deposit.cust-name AND Br-city = cust-city
```

Φυσική Σύνδεση

Natural Join: (με SQL)

```
SELECT * FROM Customer  
NATURAL JOIN Deposit;
```

- Ενώνει αυτόματα δύο πίνακες **χρησιμοποιώντας όλα τα κοινά πεδία με ίδιο όνομα.**
- Αποφεύγει διπλή εμφάνιση** της κοινής στήλης (κρατάει μία φορά το πεδίο).

Η συνένωση (JOIN)



Η **συνένωση (JOIN)** δύο σχέσεων R και S βασίζεται στη **φυσική σύνδεση** των πλειάδων τους, όταν αυτές έχουν **κοινές τιμές** σε ένα ή περισσότερα γνωρίσματα.

Βασικές μορφές JOIN:

- **Συνένωση θ -Join:**
 - Η πιο γενική μορφή συνένωσης.
 - Περιλαμβάνει όλες τις συνδυασμένες πλειάδες για τις οποίες **ισχύει μια συνθήκη θ** , π.χ. $R.a = S.b$, ή $R.x > S.y$.
 - Συμβολισμός: $R \bowtie_{\theta} S$.
- **Εξωτερική Συνένωση (Outer Join):**
 - LEFT OUTER JOIN,
 - RIGHT OUTER JOIN.

Συνένωση (ή θήτα συνένωση) (join)

συνδυασμός σχετιζόμενων πλειάδων

$$R \bowtie \langle \text{συνθήκη συνένωσης} \rangle S$$

$$(\equiv \sigma_{\langle \text{συνθήκη συνένωσης} \rangle} (R \times S))$$

Συνθήκη συνένωσης

Προτάσεις της μορφής

$$A_i \langle \text{τελεστής σύγκρισης} \rangle B_j$$

$=, >, <, \neq, \geq, \leq$

όπου A_i γνώρισμα της R , B_j γνώρισμα της S , και $\text{dom}(A_i) = \text{dom}(B_j)$

Συνένωση (ή θήτα συνένωση) (join)

- το αποτέλεσμα είναι οι συνδυασμοί πλειάδων που ικανοποιούν τη συνθήκη
- η συνθήκη αποτιμάται για κάθε συνδυασμό
- αποτέλεσμα σχέση Q με $n + m$ γνωρίσματα
- πλειάδες με τιμή null σε γνώρισμα συνένωσης δεν εμφανίζονται στο αποτέλεσμα

Συνένωση (ή Θήτα συνένωση) (join)

$$U \bowtie_{A < D} V$$

U

A	B	C
1	2	3
6	7	8
9	7	8

V

B	C	D
2	3	4
2	3	5
7	8	10

A	U.B	U.C	V.B	V.C	D
1	2	3	2	3	4
1	2	3	2	3	5
1	2	3	7	8	10
6	7	8	7	8	10
9	7	8	7	8	10

Συνένωση Ισότητας (equi join)

όταν χρησιμοποιείται μόνο τελεστής ισότητας

Συνθήκη συνένωσης

Προτάσεις της μορφής

$$A_i = B_j$$

όπου A_i γνώρισμα της R , B_j γνώρισμα της S , και $\text{dom}(A_i) = \text{dom}(B_j)$

Συνένωση Ισότητας

Συνένωση Ισότητας (equi join)

R

A	B
1	2
3	4

S

B	C	D
2	5	6
4	7	8
9	10	11

A	R.B	S.B	C	D
1	2	2	5	6
3	4	4	7	8

R $\bowtie$ **S**

R.B = S.B

Συνένωση Ισότητας

EquiJoin: (με SQL)

```
SELECT * FROM Customer  
JOIN Deposit ON Customer.cust-name = Deposit.cust-name;
```


Συνένωση (ή θήτα συνένωση) (join)

Να βρούμε όλους τους πελάτες (Customer) και τις καταθέσεις τους (Deposit) όπου οι πελάτες ζουν σε διαφορετική πόλη από το υποκατάστημα (Branch) στο οποίο έχουν καταθέσεις.

```
SELECT Customer.cust_name, Deposit.balance  
FROM Customer  
JOIN Deposit ON Customer.cust_name = Deposit.cust_name  
JOIN Branch ON Deposit.br_name = Branch.br_name  
WHERE Customer.cust_city <> Branch.br_city;
```

INNER JOIN

Ο όρος **JOIN** είναι απλώς μια συντόμευση για το **INNER JOIN**.

Μπορούμε να γράψουμε την INNER JOIN και επιστρέφει μόνο τις εγγραφές που έχουν αντιστοιχία και στους δύο πίνακες με βάση τη συνθήκη συνένωσης (ON).

Παράδειγμα SQL:

```
SELECT Customer.cust_name, Borrow.amount  
FROM Customer  
INNER JOIN Borrow ON Customer.cust_name = Borrow.cust_name;
```

Συνενώνει (INNER JOIN) τους πίνακες Customer και Borrow στη στήλη cust_name.

Εμφανίζει μόνο όσους πελάτες έχουν πάρει δάνειο.

Επιστρέφει:

- το όνομα του πελάτη,
- το ποσό του δανείου.

Σύγκριση:

Τύπος Συνένωσης

EquiJoin

Natural Join

Θ-Join (γενική)

Συνθήκη

ΜΟΝΟ ισότητα

Αυτόματη ισότητα στις
κοινές στήλες

Οποιαδήποτε

Διπλές Στήλες

✓ Ναι

✗ Όχι (συγχωνεύει)

✓ Ναι

Εξωτερική Συνένωση (Outer Join)



Left Outer Join

Ο **Left Outer Join** διατηρεί όλες τις πλειάδες (γραμμές) της αριστερής σχέσης, ακόμα κι αν δεν έχουν αντιστοιχία στη δεξιά.

Για κάθε πλειάδα της **αριστερής σχέσης** που **δεν "ταιριάζει"** με καμία της δεξιάς, τα πεδία της δεξιάς συμπληρώνονται με **NULL**.



Παράδειγμα SQL:

```
SELECT * FROM Customer  
LEFT OUTER JOIN Deposit ON Customer.cust-name = Deposit.cust-name;
```

Φέρνει **όλους τους πελάτες** (Customer) και — αν έχουν κατάθεση (Deposit) — την επισυνάπτει. Αν **δεν έχουν**, τα πεδία από το Deposit γίνονται **NULL**.

cust_name	street	cust_city	br_name	acc_number	balance
Γιώργος	Πατησίων 10	Αθήνα	Κέντρο	A-101	1200.00
Μαρία	Τρικούπη 12	Πάτρα	Ομόνοια	A-102	1500.00
Αντώνης	Κοραή 5	Θεσσαλονίκη	NULL	NULL	NULL

Right Outer Join

Η **Right Outer Join** συνδυάζει **όλες τις πλειάδες (γραμμές) της δεξιάς σχέσης** με τις αντίστοιχες πλειάδες της αριστερής, **κρατώντας και τις "ορφανές" πλειάδες της δεξιάς** ακόμα κι αν **δεν ταιριάζουν** με κάποια στην αριστερή.

Για τις δεξιές πλειάδες που **δεν βρίσκουν αντιστοιχία**, τα γνωρίσματα από την αριστερή σχέση συμπληρώνονται με **NULL**.

Παράδειγμα SQL:

```
SELECT Borrow.loan_number, Borrow.amount, Borrow.br_name,  
       Customer.cust_name, Customer.street, Customer.cust_city  
FROM Borrow  
RIGHT OUTER JOIN Customer ON Borrow.cust_name = Customer.cust_name;
```

Φέρνει **όλες** τις εγγραφές από την σχέση Customer (δεξιά σχέση) και τις συνδυάζει με την Borrow (αριστερή). Αν κάποιος Customer δεν έχει δάνειο (Borrow), τότε οι στήλες του Borrow θα έχουν NULL.

loan_number	amount	cust_name	street	cust_city
L-101	1000	Γιώργος	Πατησίων 10	Αθήνα
NULL	NULL	Μαρία	Τρικούπη 12	Πάτρα
NULL	NULL	Αντώνης	Κοραή 5	Θεσσαλονίκη

Πίνακας:
Διαφορές
Ειδών JOIN
στη Σχεσιακή
Άλγεβρα

Τύπος JOIN	Περιγραφή	Σχεσιακή Άλγεβρα	Περιλαμβάνει Μη Ταιριασμένες Γραμμές;
Θεματική Συνένωση (θ-join)	Γενική σύνδεση με συνθήκη (π.χ. =, <, >)	$\sigma(\text{συνθήκη})(R \times S)$	✗ Όχι
Συνένωση Ισότητας (equi-join)	Ειδική περίπτωση θ-join με μόνο ισότητες	$R \bowtie (R.A = S.B) S$	✗ Όχι
Φυσική Συνένωση (natural join)	Συνένωση με αυτόματη σύγκριση και συγχώνευση κοινών πεδίων	$R \bowtie S$ (χωρίς ρητή συνθήκη)	✗ Όχι
Left Outer Join	Όλες οι γραμμές από R, με NULL όπου δεν υπάρχει αντιστοίχιση στη S	$R \bowtie\!\!\!\bowtie S$	✓ Ναι (μη ταιριασμένες από R)
Right Outer Join	Όλες οι γραμμές από S, με NULL όπου δεν υπάρχει αντιστοίχιση στη R	$R \bowtie\!\!\!\bowtie S$	✓ Ναι (μη ταιριασμένες από S)

Εμφωλευμένα ερωτήματα

Πολλές φορές δεν χρειάζεται πραγματικά η σύνδεση.

Παράδειγμα:

Αρ. λογαριασμού σε καταστήματα της Αθήνας.

Χρειαζόμαστε μόνο να ξέρουμε ποια καταστήματα είναι στην Αθήνα

```
SELECT br-name FROM branch  
WHERE Br-city = 'Αθήνα'
```

Παράγεται μια λίστα ονομάτων που μπορούμε να χρησιμοποιήσουμε.

Συνεπώς:

```
SELECT acc-no FROM Deposit  
WHERE br-name IN (SELECT br-name FROM branch  
WHERE Br-city = 'Αθήνα')
```

Το ίδιο παράδειγμα με σύνδεση:

```
SELECT Deposit.acc-no  
FROM Deposit  
JOIN Branch ON Deposit.br-name = Branch.br-name  
WHERE Branch.br-city = 'Αθήνα';
```


Εισαγωγή στην Κυβερνοασφάλεια



Πως μπορούμε να σπάσουμε έναν κωδικό πρόσβασης

- Το σπάσιμο του κωδικού πρόσβασης (password cracking) είναι η διαδικασία απόπειρας απόκτησης μη εξουσιοδοτημένης πρόσβασης σε περιορισμένα συστήματα με τη χρήση κοινών κωδικών ή αλγορίθμων που μαντεύουν τους κωδικούς πρόσβασης.
- Με άλλα λόγια, είναι η τέχνη της απόκτησης του σωστού κωδικού πρόσβασης που δίνει πρόσβαση σε ένα σύστημα που προστατεύεται από μια μέθοδο ελέγχου ταυτότητας.
- Η διαδικασία του **cracking** μπορεί να περιλαμβάνει είτε τη σύγκριση αποθηκευμένων κωδικών πρόσβασης με μια λίστα λέξεων είτε τη χρήση αλγορίθμων για την παραγωγή κωδικών πρόσβασης που ταιριάζουν.



Τεχνικές cracking για κωδικούς πρόσβασης

Υπάρχουν ορισμένες τεχνικές που μπορούν να χρησιμοποιηθούν για το cracking των κωδικών πρόσβασης. Θα περιγράψουμε τις πιο συχνά χρησιμοποιούμενες:

- **Dictionary attack**
- **Brute force attack**
- **Rainbow table attack**
- **Guess**
- **Spidering**

Dictionary attack

- Αυτή η μέθοδος περιλαμβάνει τη χρήση λίστας λέξεων για σύγκριση με τους κωδικούς πρόσβασης των χρηστών.



Brute force attack

(Επίθεση ωμής βίας)

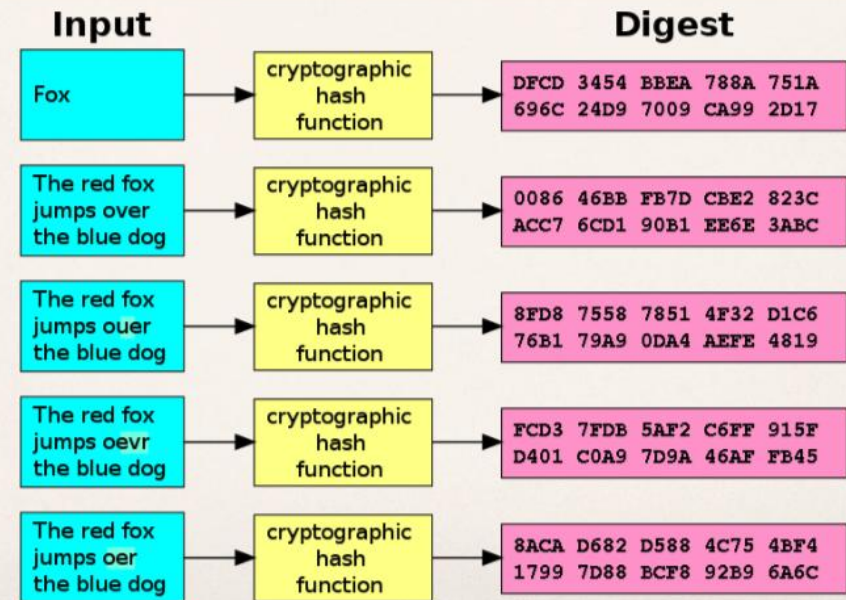
- Αυτή η μέθοδος είναι παρόμοια με την dictionary attack.
- Οι brute force attacks χρησιμοποιούν αλγορίθμους που συνδυάζουν αλφαριθμητικούς χαρακτήρες και σύμβολα για να βρουν κωδικούς πρόσβασης για την επίθεση.
- Για παράδειγμα, ένας κωδικός πρόσβασης π.χ. "password", μπορεί επίσης να δοκιμαστεί ως p@\$word χρησιμοποιώντας την brute force attack.



Rainbow table attack

- Αυτή η μέθοδος χρησιμοποιεί pre-computed hashes.
- Ας υποθέσουμε ότι έχουμε μια βάση δεδομένων που αποθηκεύει κωδικούς πρόσβασης ως md5 hashes.
- Μπορούμε να δημιουργήσουμε μια άλλη βάση δεδομένων που έχει md5 hashes από κοινά χρησιμοποιούμενους κωδικούς πρόσβασης.
- Στη συνέχεια, μπορούμε να συγκρίνουμε το hash του κωδικού πρόσβασης που έχουμε στα αποθηκευμένα hashes στη βάση δεδομένων. Αν βρεθεί μια αντιστοιχία (match), τότε έχουμε τον κωδικό πρόσβασης.

What is a Hash?



Guess

- Όπως υποδηλώνει το όνομα, αυτή η μέθοδος περιλαμβάνει την εικασία.
- Ορισμένοι κωδικοί πρόσβασης όπως οι: password, admin κ.λπ. χρησιμοποιούνται ευρέως ή ορίζονται ως οι προεπιλεγμένοι κωδικοί πρόσβασης.
- Εάν δεν έχουν αλλάξει ή αν ο χρήστης είναι απρόσεκτος κατά την επιλογή των κωδικών πρόσβασης, τότε μπορούν εύκολα να μαντευθούν.



Spidering

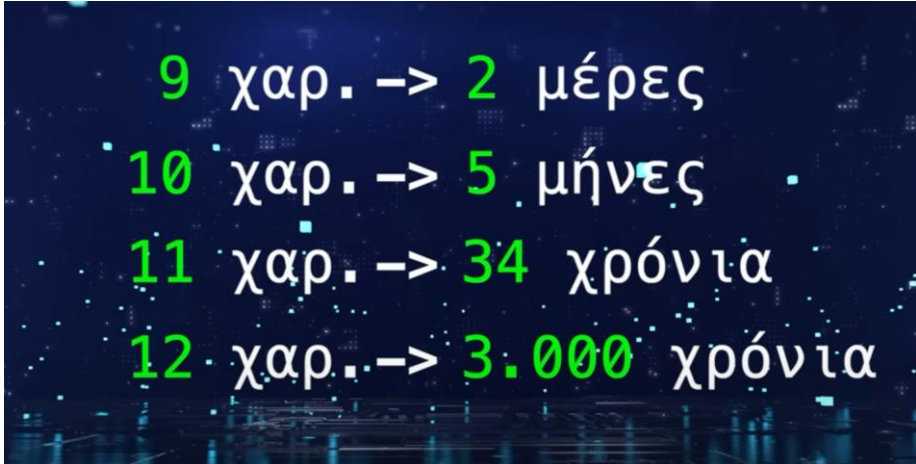
- Οι περισσότεροι οργανισμοί χρησιμοποιούν κωδικούς πρόσβασης που περιέχουν πληροφορίες σχετικές με την εταιρεία.
- Αυτές οι πληροφορίες μπορούν να βρεθούν σε ιστότοπους της εταιρείας, σε κοινωνικά μέσα όπως το facebook, το twitter κλπ.
- Το spidering συλλέγει πληροφορίες από αυτές τις πηγές για να βρει λίστες λέξεων.
- Στη συνέχεια, οι λίστες των λέξεων χρησιμοποιούνται για την εκτέλεση επιθέσεων dictionary και brute force.



Η ισχύς του κωδικού πρόσβασης

Η ισχύς του κωδικού πρόσβασης είναι το μέτρο της αποτελεσματικότητας του κωδικού πρόσβασης για να αντισταθεί στις επιθέσεις cracking του κωδικού πρόσβασης. Η ισχύς ενός κωδικού πρόσβασης καθορίζεται από τα ακόλουθα:

- Μήκος: ο αριθμός χαρακτήρων που περιέχει ο κωδικός πρόσβασης.
- Πολυπλοκότητα: Χρησιμοποιεί έναν συνδυασμό γραμμάτων, αριθμών και συμβόλων.
- Δυσκολία πρόβλεψης: είναι κάτι που δεν μπορεί να μαντέψει εύκολα ένας attacker.



9	χαρ.	->	2	μέρες
10	χαρ.	->	5	μήνες
11	χαρ.	->	34	χρόνια
12	χαρ.	->	3.000	χρόνια

Σχετικό χιουμοριστικό Video: <https://bit.ly/3FMqvVn>

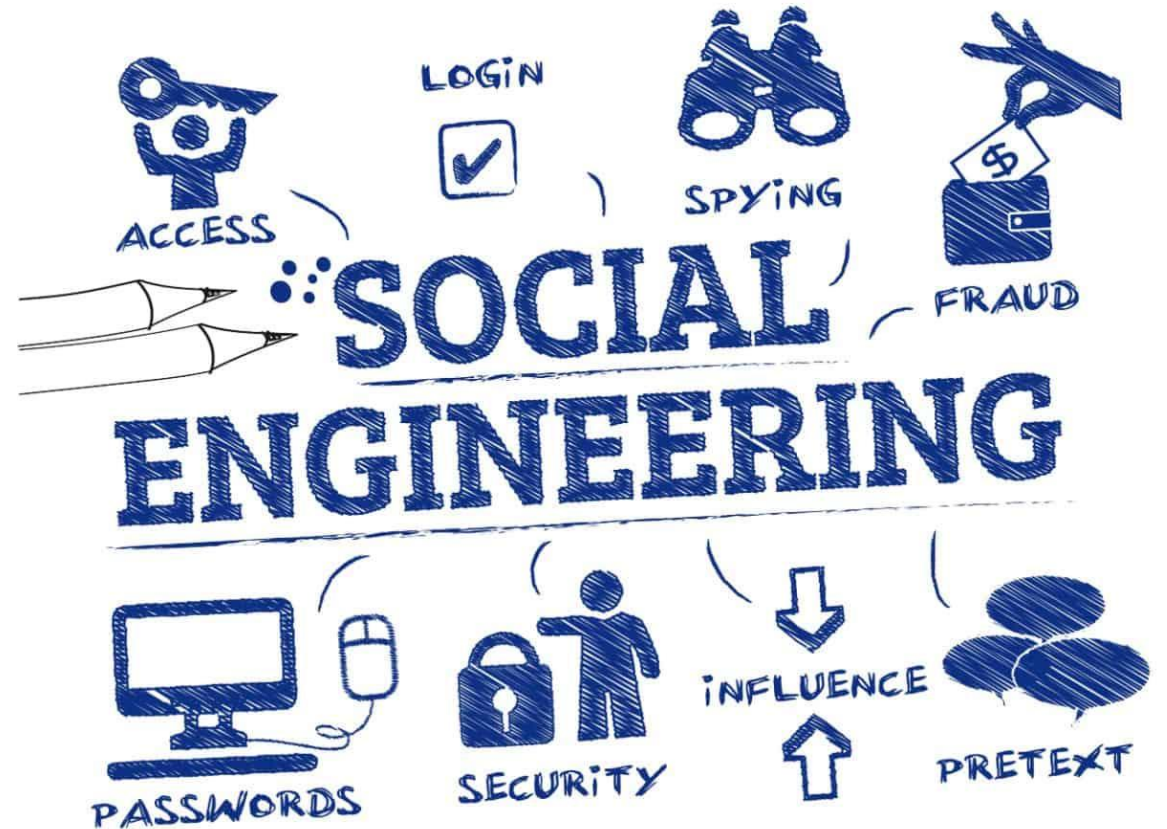
Passwords - Cybersecurity για όλους | Yiannis Sarakatsanis

Ασφάλεια Πληροφοριών



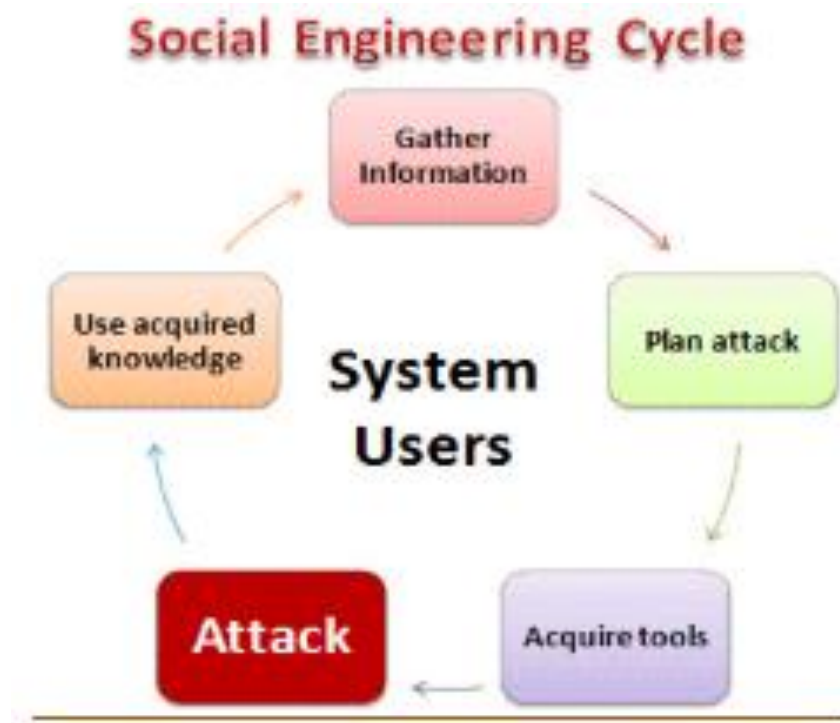
Κοινωνική μηχανική

- Η κοινωνική μηχανική (social engineering) είναι η τέχνη του χειρισμού των χρηστών ενός υπολογιστικού συστήματος ώστε να αποκαλύψουν τις εμπιστευτικές πληροφορίες που μπορούν να χρησιμοποιηθούν για να αποκτηθεί μη εξουσιοδοτημένη πρόσβαση σε ένα υπολογιστικό σύστημα.
- Ο όρος μπορεί επίσης να περιλαμβάνει δραστηριότητες όπως η εκμετάλλευση της ανθρώπινης καλοσύνης, της απληστίας και της περιέργειας για να αποκτηθεί πρόσβαση στο πληροφοριακό σύστημα.
- Είναι πολύ σημαντικό να γνωρίζουμε τα κόλπα που χρησιμοποιούν οι hackers για να εξαπατήσουν τους χρήστες ώστε να αποκαλύψουν τις πληροφορίες σύνδεσης (login information) ώστε να μπορέσουμε να προστατέψουμε τα υπολογιστικά συστήματα.



Πως ακριβώς δουλεύει η κοινωνική μηχανική

- **Συγκέντρωση πληροφοριών (*gather information*):** Αυτό είναι το πρώτο στάδιο, όπου ο attacker, μαθαίνει όσα περισσότερα μπορεί για το θύμα. Οι πληροφορίες συλλέγονται από ιστότοπους της εταιρείας, άλλες εκδόσεις (publications) και μερικές φορές μέσω συνομιλιών με τους χρήστες του συστήματος-στόχο (target system).
- **Σχεδιασμός επίθεσης (*plan attack*):** Οι attackers σχεδιάζουν πώς σκοπεύουν να εκτελέσουν την επίθεση.
- **Απόκτηση εργαλείων (*acquire tools*):** Αυτά περιλαμβάνουν τα προγράμματα υπολογιστή (computer programs) που θα χρησιμοποιήσει ένας attacker κατά την εκκίνηση της επίθεσης.
- **Επίθεση (*attack*):** Αξιοποίηση των αδυναμιών του συστήματος-στόχου.
- **Χρήση της αποκτηθείσας γνώσης (*use acquired knowledge*):** Οι πληροφορίες που συλλέγονται κατά τη διάρκεια των τακτικών της κοινωνικής μηχανικής (social engineering tactics), όπως τα ονόματα των κατοικίδιων ζώων, οι ημερομηνίες γέννησης των ιδρυτών της οργάνωσης κ.λπ. χρησιμοποιούνται στις επιθέσεις για τον κωδικό πρόσβασης.



Κοινές τεχνικές κοινωνικής μηχανικής

- Αξιοποίηση της εξοικείωσης (familiarity exploit).
- Εκφοβιστικές περιστάσεις (Intimidating Circumstances).
- Ηλεκτρονικό ψάρεμα (phishing).
- Κοντινή απόσταση με το υποψήφιο θύμα (tailgating).
- Εκμετάλλευση της ανθρώπινης περιέργειας (exploiting human curiosity).
- Εκμετάλλευση της ανθρώπινης απληστίας (exploiting human greed).



Familiarity Exploit



Intimidating
Circumstances



Phishing



Tailgating



Human Emotions

Αξιοποίηση της εξοικείωσης (familiarity exploit).

- Οι χρήστες είναι λιγότερο ύποπτοι με τους ανθρώπους με τους οποίους είναι εξοικειωμένοι.
- Ένας attacker μπορεί να εξοικειωθεί με τους χρήστες του συστήματος-στόχου πριν από την επίθεση της κοινωνικής μηχανικής.
- Ο attacker μπορεί να αλληλεπιδράσει με τους χρήστες κατά τη διάρκεια γευμάτων, όταν οι χρήστες κάνουν διάλειμμα για να καπνίσουν, σε κοινωνικές εκδηλώσεις κ.λπ. Αυτό καθιστά τον attacker εξοικειωμένο με τους χρήστες.
- Ο attacker μπορεί επίσης να ζητήσει πληροφορίες όπως το σημείο όπου συναντήσανε τον / την σύζυγό τους στο πρώτο τους ραντεβού, το όνομα του αγαπημένου τους καθηγητή στο σχολείο κ.λπ.
- Αυτές οι πληροφορίες μπορούν να χρησιμοποιηθούν για το χακάρισμα/ σπάσιμο (hacking) των λογαριασμών ηλεκτρονικού ταχυδρομείου καθώς και άλλων λογαριασμών που υποβάλλουν παρόμοιες ερωτήσεις εάν οι χρήστες ξεχάσουν τον κωδικό πρόσβασής τους.



<https://www.youtube.com/watch?v=RgzkYLxVa3w>

Εκφοβιστικές περιστάσεις (Intimidating Circumstances).

- Οι άνθρωποι τείνουν να αποφεύγουν τους ανθρώπους που εκφοβίζουν τους άλλους γύρω τους. Χρησιμοποιώντας αυτήν την τεχνική, ο attacker μπορεί να προσποιηθεί ότι διαφωνεί έντονα με κάποιον στο τηλέφωνο, ενδεχομένως με κάποιον συνεργό του.
- Ο attacker μπορεί στη συνέχεια να ζητήσει από τους χρήστες πληροφορίες που θα χρησιμοποιηθούν για να θέσουν σε κίνδυνο την ασφάλεια του συστήματος των χρηστών.
- Οι χρήστες πιθανότατα να δώσουν τις σωστές απαντήσεις απλώς και μόνο για να αποφύγουν μια αντιπαράθεση με τον attacker.
- Αυτή η τεχνική μπορεί επίσης να χρησιμοποιηθεί για να αποφευχθεί ο έλεγχος σε ένα σημείο ελέγχου ασφάλειας.



**Intimidating
Circumstances**

Ηλεκτρονικό ψάρεμα (phishing)

- Αυτή η τεχνική χρησιμοποιεί την εξαπάτηση για την απόκτηση ιδιωτικών δεδομένων από τους χρήστες.
- Ο κοινωνικός μηχανικός (social engineer) μπορεί να προσπαθήσει να μιμηθεί έναν πραγματικό ιστότοπο όπως το Yahoo και στη συνέχεια να ζητήσει από τον ανυποψίαστο χρήστη να επιβεβαιώσει το όνομα του λογαριασμού και τον κωδικό πρόσβασης.
- Αυτή η τεχνική θα μπορούσε επίσης να χρησιμοποιηθεί για τη λήψη πληροφοριών πιστωτικών καρτών ή άλλων πολύτιμων προσωπικών δεδομένων.



Κοντινή απόσταση με το υποψήφιο θύμα (tailgating).

Η ονομασία tailgating προέρχεται από την αγγλική φράση "to tailgate", που κυριολεκτικά σημαίνει:

🚗 να ακολουθείς κάποιον από πολύ κοντινή απόσταση, κυρίως σε οδήγηση (π.χ. ένα αυτοκίνητο που "κολλάει" στο πίσω μέρος του άλλου).

Στην κυβερνοασφάλεια, η έννοια είναι μεταφορική:

👉 Ο επιτιθέμενος "κολλάει από πίσω" σε έναν εξουσιοδοτημένο υπάλληλο για να εισέλθει σε περιορισμένη περιοχή, χωρίς άδεια.



Tailgating

📌 Παράδειγμα:

Ένας άγνωστος ακολουθεί έναν υπάλληλο καθώς αυτός εισέρχεται στο κτίριο με την κάρτα του. Ο υπάλληλος κρατάει την πόρτα ανοιχτή από ευγένεια, κι έτσι ο άγνωστος (tailgater) περνάει χωρίς έλεγχο.

Εκμετάλλευση της ανθρώπινης περιέργειας (exploiting human curiosity).

- Χρησιμοποιώντας αυτήν την τεχνική, ο κοινωνικός μηχανικός μπορεί να ρίξει σκόπιμα έναν φλασάκι (flash disk) που είναι μολυσμένο με ιό σε έναν χώρο όπου ο χρήστης-θύμα μπορεί να το πάρει εύκολα.
- Ο χρήστης πιθανότατα θα συνδέσει το φλασάκι στον υπολογιστή. Το φλασάκι μπορεί να εκτελέσει αυτόματα τον ιό.
- Ο χρήστης μπορεί επίσης να μπει στον πειρασμό να ανοίξει ένα αρχείο με όνομα όπως το Έκθεση Αξιολόγησης Υπαλλήλων.docx που μπορεί να είναι ένα μολυσμένο αρχείο.



Εκμετάλλευση της ανθρώπινης απληστίας (exploiting human greed)

- Χρησιμοποιώντας αυτή την τεχνική, ο κοινωνικός μηχανικός μπορεί να δελεάσει τον χρήστη με υποσχέσεις ότι θα βγάλει πολλά χρήματα online συμπληρώνοντας ένα έντυπο και επιβεβαιώνοντας τα στοιχεία του χρησιμοποιώντας στοιχεία της πιστωτικής κάρτας κ.λπ.



Ασφάλεια Πληροφοριών

Πολιτικές Ασφάλειας Πληροφοριών



Πολιτικές Ασφάλειας

Μια Πολιτική Ασφάλειας περιλαμβάνει το σκοπό και τους στόχους της ασφάλειας, οδηγίες, διαδικασίες, κανόνες, ρόλους και υπευθυνότητες, που αφορούν στην προστασία των ΠΣ ενός οργανισμού.

Εφαρμόζουμε μια Πολιτική Ασφάλειας για τους πιο κάτω λόγους:

- Λειτουργεί ως το μέσο για την επικοινωνία των εμπλεκομένων στα ζητήματα ασφάλειας (χρήστες, διοίκηση, διαχειριστές συστημάτων κλπ.).
- Θεμελιώνεται η σημασία της ασφάλειας του ΠΣ για όλα τα μέλη του οργανισμού.
- Συμβάλλει στη δημιουργία κουλτούρας ασφάλειας.
- Σε ορισμένες περιπτώσεις αποτελεί νομική υποχρέωση.
- Αποτελεί παράγοντα εμπιστοσύνης στις σχέσεις του οργανισμού με συνεργαζόμενους φορείς και πελάτες.

Παραδείγματα Πολιτικής Ασφάλειας

Ασφάλεια Λογισμικού

- Απαγορεύεται η μη εξουσιοδοτημένη πρόσβαση σε εφαρμογές.
- Απαγορεύεται η εγκατάσταση λογισμικού που δεν έχει την απαιτούμενη άδεια χρήσης.
- Απαγορεύεται η εγκατάσταση λογισμικού χωρίς την έγκριση του υπευθύνου ασφάλειας.
- Απαγορεύεται η τροποποίηση λογισμικού χωρίς την έγκριση του υπευθύνου ασφάλειας.
- Η τροποποίηση λογισμικού των υποσυστημάτων του ΠΣ πρέπει να γίνεται πρώτα σε δοκιμαστικό περιβάλλον και μετά θα μπαίνει σε παραγωγική λειτουργία.
- Απαγορεύεται οι χρήστες να εγκαθιστούν προγράμματα από το διαδίκτυο.
- Απαγορεύεται η εκτέλεση προγραμμάτων που λαμβάνονται συνημμένα στο ηλεκτρονικό ταχυδρομείο.
- Στο ΠΣ πρέπει να υπάρχει εγκατεστημένο πρόγραμμα προστασίας από κακόβουλο και ιομορφικό λογισμικό στους εξυπηρετητές και στους σταθμούς εργασίας.
- Σε περίπτωση περιστατικού κακόβουλο λογισμικού ο σταθμός εργασίας θα απομονώνεται και θα καθαρίζεται.

Παραδείγματα Πολιτικής Ασφάλειας

Ασφάλεια Δεδομένων

Για την προστασία των δεδομένων οι χρήστες πρέπει να τηρούν τα εξής μέτρα:

- Προστασία των συνθηματικών πρόσβασης στο λειτουργικό σύστημα των σταθμών εργασίας.
- Προστασία των συνθηματικών πρόσβασης στις λογισμικό εφαρμογών.
- Η δομή των συνθηματικών θα είναι τέτοια που θα αποτρέπει την εύκολη αποκάλυψή τους.
- Τα δεδομένα δεν πρέπει να στέλνονται μέσω διαδικτύου. Στην περίπτωση που αυτό κριθεί απαραίτητο θα στέλνονται κρυπτογραφημένα.
- Πρέπει να τηρούνται εφεδρικά αντίγραφα (back up).
- Όλα τα αρχεία από το back up πρέπει να φυλάσσονται σε ασφαλές μέρος.
- Οι χρήστες έχουν ευθύνη για την προστασία φυσικών μέσων που περιέχουν δεδομένα που χρήζουν εμπιστευτικότητας.

Παραδείγματα Πολιτικής Ασφάλειας

Πολιτική ασφάλειας για τα συνθηματικά (Passwords)

Τα ισχυρά passwords έχουν τα ακόλουθα χαρακτηριστικά:

- Περιέχουν κεφαλαίους και μικρούς χαρακτήρες.
- Περιέχουν αριθμούς, γράμματα και σύμβολα.
- Έχουν μήκος τουλάχιστον δεκαπέντε αλφαριθμητικών χαρακτήρων.
- Δεν υφίστανται ως λέξεις σε οποιαδήποτε γλώσσα.
- Δεν βασίζονται σε προσωπικές πληροφορίες, ονόματα κτλ.
- Τα passwords δεν πρέπει ποτέ να γράφονται ή να αποθηκεύονται on-line.

Παραδείγματα Πολιτικής Ασφάλειας

Πολιτική ασφάλειας για τα συνθηματικά (Passwords)

Ας δούμε κάποιους βασικούς κανόνες για τα συνθηματικά που πρέπει να περιέχονται στην πολιτική ασφάλειας:

- Όλα τα passwords των συστημάτων θα πρέπει να αλλάζουν σε τακτική βάση.
- Όλα τα passwords των χρηστών θα πρέπει να αλλάζουν τουλάχιστον κάθε έξι μήνες.
- Οι λογαριασμοί των χρηστών που έχουν εξουσιοδοτηθεί με προνόμια στα συστήματα μέσω ομαδικών συνδρομών ή προγραμμάτων πρέπει να χρησιμοποιούν ένα μοναδικό password για τον συγκεκριμένο λογαριασμό.
- Τα passwords δεν πρέπει να εισέρχονται μέσα σε ηλεκτρονικά μηνύματα ή άλλα μέσα ηλεκτρονικής επικοινωνίας.

Παραδείγματα Πολιτικής Ασφάλειας

Πολιτική ασφάλειας για τα συνθηματικά (Passwords)

Παρακάτω ακολουθεί μία λίστα από πράγματα που πρέπει να αποφευχθούν:

- Να μην αποκαλύπτεται το password μέσω τηλεφώνου σε κανέναν.
- Να μην αποκαλύπτεται το password σε ένα ηλεκτρονικό μήνυμα.
- Να μην αποκαλύπτεται το password στον εκάστοτε προϊστάμενο
- Να μην αποκαλύπτεται προφορικά το password μπροστά σε άλλους.
- Να μην αποκαλύπτεται η μορφή του password.
- Να μην αποκαλύπτεται το password σε ερωτηματολόγια ή σε φόρμες ασφαλείας.
- Να μην αποκαλύπτεται το password σε συναδέλφους κατά την διάρκεια διακοπών.



Ανακεφαλαίωση

Τι είδαμε στο σημερινό μάθημα

- Συζήτηση τέταρτης εργασίας: Υλοποίηση βάσης με SQL.
 - Σχεσιακή άλγεβρα: Καρτεσιανό γινόμενο, Φυσική σύνδεση, συνένωση.
 - Εισαγωγή στην Κυβερνοασφάλεια.
- 

Περιεχόμενα Μαθήματος

Τι θα δούμε στο επόμενο μάθημα Βάσεις δεδομένων

- Το περιβάλλον της Βάσης Δεδομένων, σύστημα αρχείων,
- Διαδικασία ανάπτυξης της βάσης δεδομένων,
- Μοντέλο Οντοτήτων-Συσχετίσεων (ΟΣ),
- Λογική σχεδίαση βάσης δεδομένων και το Σχεσιακό Μοντέλο,
- Υλοποίηση βάσης με SQL - Εισαγωγή στην Σχεσιακή Άλγεβρα
- Σχεσιακή Άλγεβρα, επερωτήσεις,
- Πολιτικές Ασφάλειας.

Προτεινόμενη Βιβλιογραφία:

Παράδειγμα εργασίας επόμενης εβδομάδας

Προτεινόμενη Βιβλιογραφία:

1. Βιβλίο [133031084]: Συστήματα Διαχείρισης Βάσεων Δεδομένων, 3η Βελτιωμένη Έκδοση, Ramakrishnan Raghu, Gehrke Johannes, Δέρβος Δημήτριος, Ευαγγελίδης Γεώργιος (Επιστ. Επιμέλεια) Λεπτομέρειες
2. Βιβλίο [102070677]: Συστήματα Βάσεων Δεδομένων, 7η Εκδ., Silberschatz Abraham, Korth Henry, Sudarshan S. Λεπτομέρειες
3. Βιβλίο [68406015]: ΕΙΣΑΓΩΓΗ ΣΤΙΣ ΒΑΣΕΙΣ ΔΕΔΟΜΕΝΩΝ, ΤΑΜΠΑΚΑΣ ΒΑΣΙΛΕΙΟΣ Λεπτομέρειες
4. Βιβλίο [12186]: Θεμελιώδεις αρχές συστημάτων βάσεων δεδομένων, Elmasri Ramez, Navathe Shamkant B. Λεπτομέρειες
5. Βιβλίο [133024642]: Συστήματα βάσεων δεδομένων, Coronel Carlos, Morris Steven (Συγγρ.) - Αντωνιάδης Νίκος, Σκιαδόπουλος Σπύρος, Γκαράνη Γεωργία, Μπεχτσής Δημήτρης, Κολωνιάρη Γεωργία (Επιμ.) Λεπτομέρειες
6. Βερούκιος, Β. Σ., & Βασιλακόπουλος, Μ. Γ. (2022). Συστήματα Βάσεων Δεδομένων – Βασικές Αρχές και Πρακτικές Εφαρμογές [Προπτυχιακό εγχειρίδιο]. Κάλλιπος, Ανοικτές Ακαδημαϊκές Εκδόσεις. <http://dx.doi.org/10.57713/kallipos-36>
7. Σκουρλάς, Χ. (2024). Συστήματα Βάσεων Δεδομένων Τόμος Α' [Προπτυχιακό εγχειρίδιο]. Κάλλιπος, Ανοικτές Ακαδημαϊκές Εκδόσεις. <http://dx.doi.org/10.57713/kallipos-397>
8. Σκουρλάς, Χ. (2024). Συστήματα Βάσεων Δεδομένων Τόμος Β' [Προπτυχιακό εγχειρίδιο]. Κάλλιπος, Ανοικτές Ακαδημαϊκές Εκδόσεις. <http://dx.doi.org/10.57713/kallipos-973>
9. Λουκόπουλος, Θ., & Θεοδωρίδης, Ε. (2016). Εισαγωγή στην SQL [Εργαστηριακός Οδηγός]. Κάλλιπος, Ανοικτές Ακαδημαϊκές Εκδόσεις. <http://dx.doi.org/10.57713/kallipos-709>
10. Συμεωνίδης, Π., & Γούναρης, Α. (2015). Βάσεις, αποθήκες και εξόρυξη δεδομένων με τον SQL Server. Εργαστηριακός Οδηγός]. Κάλλιπος, Ανοικτές Ακαδημαϊκές Εκδόσεις. <http://dx.doi.org/10.57713/kallipos-888>
11. Ηρακλής Βαρλάμης. Βάσεις Δεδομένων. Χαροκόπειο Πανεπιστήμιο.
12. MySQL Documentation (Oracle): <https://dev.mysql.com/doc/>
13. ERD Plus Documentation: <https://erdplus.com>
14. SQL Tutorial: <https://www.w3schools.com/sql/default.asp>
15. PostgreSQL Documentation (The PostgreSQL Global Development Group): <https://www.postgresql.org/docs/>
16. Kaggle Datasets: <https://www.kaggle.com/datasets>
17. MongoDB Documentation: <https://www.mongodb.com/docs>
18. Apache Hadoop: <https://hadoop.apache.org/>
19. Google BigQuery Documentation: <https://cloud.google.com/bigquery/docs>
20. Google Cloud Spanner Documentation: <https://cloud.google.com/spanner/docs>
21. Amazon Aurora Documentation: <https://aws.amazon.com/rds/aurora>



ΤΜΗΜΑ ΠΛΗΡΟΦΟΡΙΚΗΣ & ΤΗΛΕΠΙΚΟΙΝΩΝΙΩΝ
ΣΧΟΛΗ ΠΛΗΡΟΦΟΡΙΚΗΣ & ΤΗΛΕΠΙΚΟΙΝΩΝΙΩΝ
ΠΑΝΕΠΙΣΤΗΜΙΟ ΙΩΑΝΝΙΝΩΝ

Εισαγωγή στις Βάσεις Δεδομένων και στα Συστήματα
Διαχείρισης Σχεσιακών ΒΔ Ι.

Thanks For Watching

i.stylios@uoi.gr
istylios@aegean.gr